PORTAL STUDIO · מידע ואבטחה

איך המידע שלך מאוחסן ומוגן

תמונת מצב בשפה פשוטה: איפה יושב כל המידע במערכת, אילו שכבות הגנה עוטפות אותו, איך מתבצעת מחיקת מידע, ואיפה הדברים עומדים מבחינת חוק ופרטיות.

☁ אחסון באירופה · Railway
🔒 סודות מוצפני AES-256
🔑 סיסמאות מגובבות
🚪 בידוד מלא בין עסקים

1 איפה הכל מאוחסן

כל המידע במערכת יושב באחד משלושה מקומות, כולם בענן על Railway בשרתים באמסטרדם (אירופה).

מסד הנתונים הראשי

PostgreSQL

הלב של המערכת: משתמשים, עסקים, שיחות, אנשי קשר, לידים, פגישות, חשבוניות ומנויים.

☁ Railway · אמסטרדם (EU)

קבצים לכל עסק

אחסון קבצים

מסמכי הידע והקונטקסט שכל עסק מעלה (מה שהסוכן קורא). כל עסק בתיקייה מבודדת משלו.

☁ דיסק מוצמד ב-Railway

תור זמני

Redis

לא מאחסן מידע קבוע — רק תור משימות זמני (למשל הרצת הסוכן על הודעה). מתרוקן מעצמו.

☁ Railway · מוגן בסיסמה

2 איזה מידע נשמר ורמת ההגנה שלו

כל המידע מחולק לשלוש קבוצות. העמודה מימין מציינת את רמת ההגנה של כל פריט.

● מוצפן — AES-256
● מגובב (חד-כיווני) — סיסמאות
● גלוי בבסיס הנתונים — מוגן בשכבות הגישה

סוג המידע	מה זה כולל	איפה	רמת הגנה
א · מידע של המערכת עצמה			
חשבונות משתמשים	אימייל, שם, תפקיד, סטטוס	PostgreSQL	גלוי
סיסמאות	הסיסמה עצמה לא נשמרת — רק טביעה מתמטית שלה	PostgreSQL	מגובב bcrypt
הגדרות פלטפורמה	קטלוג סוכנים, תבניות מסמכים, כללי אוטומציה, הרשאות	PostgreSQL	גלוי
ב · מידע שמצטבר לפי השימוש			
שיחות והודעות	תוכן השיחות בין הלקוחות לסוכן (וואטסאפ + צ'אט)	PostgreSQL	גלוי
לידים ופניות	טלפון, אימייל, תחום עניין, תשובות משאלון	PostgreSQL	גלוי
פגישות ותורים	מועדים, אנשי קשר, רשימת המתנה	PostgreSQL	גלוי
חיוב וכספים	חשבוניות, מנויים, מסלול תמחור, הוצאות	PostgreSQL	גלוי
יומן פעולות (Audit)	מי עשה מה ומתי — למעקב ואבטחה	PostgreSQL	גלוי
ג · מידע של בעלי העסקים והלקוחות שלהם			
פרופיל העסק	שם, מיתוג, טלפון בעל העסק, הגדרות סוכן	PostgreSQL	גלוי
אנשי קשר (לקוחות הקצה)	טלפון ואימייל של הלקוחות של כל עסק	PostgreSQL	גלוי
חיבור וואטסאפ	מפתח הגישה (Token) של ה-WhatsApp של העסק	PostgreSQL	מוצפן
חיבורי גוגל (Gmail/יומן)	אסימוני גישה לחשבון הגוגל של העסק	PostgreSQL	מוצפן

סוג המידע	מה זה כולל	איפה	רמת הגנה
חשבונית ירוקה	פרטי הגישה למערכת הסליקה/חשבוניות	PostgreSQL	מוצפן
מסמכי ידע של העסק	קבצים שהעסק מעלה + הוראות מפעיל נסתרות	אחסון קבצים	גלוי · מבודד לעסק

3 שכבות ההגנה על המידע

כך המידע מוגן במערכת, מקצה לקצה.

סיסמאות בלתי הפיכות
סיסמאות משתמשים נשמרות מגובבות (bcrypt) בלבד. אף אחד — כולל אתה — לא יכול לראות את הסיסמה של משתמש.

מפתחות וסודות מוצפנים
אסימוני הגישה של וואטסאפ, גוגל וחשבונית ירוקה מוצפנים בתקן AES-256-GCM לפני שהם נכנסים לבסיס הנתונים. מי שישיג את ה-DB לא יוכל להשתמש בהם.

הפרדה מלאה בין עסקים
כל בקשה נבדקת מול ההרשאות — עסק אחד לא יכול לגשת למידע של עסק אחר. שכבת הגנה נוספת מונעת "בריחה" מתיקיית הקבצים של העסק.

חיבור מבודד לבסיס הנתונים
החיבור בין השרת ל-Postgres עובר ברשת הפנימית הפרטית של Railway — מבודד מהאינטרנט הציבורי, לא חשוף לציתות חיצוני.

התחברות מאובטחת + הגנה מהצפות
כניסה דרך אסימון JWT שפג אחרי 7 ימים, והגבלת קצב בקשות (120 לדקה) שחוסמת ניסיונות פריצה אוטומטיים.

נעילת ווידג'ט הצ'אט לדומיינים מאושרים
ווידג'ט הצ'אט של כל עסק רץ רק בדומיינים שהעסק אישר. ניסיון להפעיל אותו מאתר לא מורשה נחסם, וזיהוי דומיין חדש מעלה התראה במערכת.

כדאי לדעת: תוכן ההודעות ופרטי הלקוחות (טלפון/אימייל) נשמרים בבסיס הנתונים בצורה גלויה, ומוגנים בשכבות הגישה שסביבו (הצפנת חיבורים, בידוד, הרשאות). זהו מצב נפוץ ותקין; הצפנה גם ברמת הפריט עצמו היא שכבה נוספת אפשרית לעתיד.

4 מחיקת מידע וזכות להישכח

המערכת תומכת בשני סוגי מחיקה, בהתאם לדרישות חוק הגנת הפרטיות (תיקון 13) וה-GDPR.

מחיקת לקוח בודד

לפי בקשת "מחקו אותי" של לקוח קצה — המערכת מוחקת לצמיתות את איש הקשר וכל המידע שלו: שיחות, הודעות, פגישות ופניות. חשבוניות שכבר הופקו נשמרות לפי חובת שמירה חוקית, מנותקות מהשם.

מיידי · מתועד ביומן

מחיקת עסק שלם

בסגירת חשבון — העסק נעלם מהמערכת באופן מיידי, ואחרי חלון של 30 יום נמחקים לצמיתות כל הנתונים והקבצים שלו. בתוך החלון ניתן לשחזר, כך שמחיקה בטעות נמנעת.

חלון 30 יום · הפיך

5 המצב מבחינת חוק ופרטיות

המערכת מחזיקה מידע אישי של אנשים, ולכן חלים עליה שני מסגרות עיקריות.

IL חוק הגנת הפרטיות (ישראל)

המערכת מאחסנת טלפונים, אימיילים ותוכן שיחות — מאגר מידע לכל דבר. תיקון 13 לחוק (בתוקף מ-2025) מחמיר את הדרישות והקנסות.

- אמצעי אבטחה ההולמים מאגר ברמה "בינונית" — בקרת גישה, הצפנת סודות, יומן פעולות והפרדה בין לקוחות — מיושמים במערכת.
- זכויות נושאי המידע (עיון, תיקון, מחיקה) — נתמכות דרך מנגנון המחיקה.
- קיימות טיוטות של מדיניות פרטיות והסכם עיבוד מידע (DPA) מול הלקוחות, מותאמות למערכת — ממתינות לאישור עורך דין לפני פרסום.

GDPR EU (אירופה)

השרתים באמסטרדם — יתרון לשמירת מידע באיחוד האירופי. מידע הנשלח לעיבוד מחוץ לאיחוד (למשל תוכן הודעה לסוכן ה-AI של Anthropic/Claude) מגובה במנגנוני הגנה מקובלים; פרט זה מגולה במדיניות הפרטיות.

- מדיניות פרטיות שמסבירה איזה מידע נאסף, למה, וכמה זמן נשמר.
- הסכם עיבוד מידע (DPA) מול כל עסק שמשתמש במערכת, כולל רשימת ספקי המשנה.

⚠ **הבהרה:** זו אינה חוות דעת משפטית. הבסיס הטכני והמסמכים מוכנים ומותאמים, אך לפני עלייה עם לקוחות אמיתיים בהיקף — האישור הסופי צריך לעבור דרך עו״ד המתמחה בהגנת הפרטיות.
